

Sistema de Informação

Nomes Geovanne, Samuel, Eros, Rodrigo

Turma: SIS251N01

DOSSIÊ DE INCIDENTE CIBERNÉTICO: CASO E-TECH

Status: CRÍTICO / URGENTE

Destinatário: Equipe de Resposta a Incidentes (Alunos)

Empresa: E-Tech S.A. (E-commerce de Eletrônicos)

Este documento contém as informações coletadas preliminarmente pela equipe de TI da E-Tech após a detecção de anomalias massivas nos sistemas na última madrugada. Sua missão é analisar as evidências em grupo e propor soluções imediatas e definitivas. O relógio está correndo!

MISSÃO 1: Diagnóstico de Impacto (Princípios de Segurança)

O impacto inicial foi sentido em diversas áreas da empresa. Analisem os fatos abaixo e classifiquem qual pilar da tríade CID (Confidencialidade, Integridade e Disponibilidade) foi o foco principal da violação em cada ponto:

Fato Identificado	Princípio Violado (C, I ou D)	Justificativa
O site principal de vendas está apresentando erro 503 (fora do ar) e ninguém consegue comprar.	Disponibilidade (D)	O sistema está inacessível para os usuários legítimos e clientes, interrompendo a operação comercial da empresa.

Alguns produtos que custavam R\$ 5.000,00 apareceram no carrinho de compras por R\$ 0,50 centavos.	Integridade (I)	Houve uma modificação não autorizada e indevida nos dados de precificação dos produtos, corrompendo a precisão da informação.
Uma lista com e-mails e CPFs de 50.000 clientes foi postada anonimamente em um fórum hacker.	Confidencialidade (C)	Dados privados e sensíveis de clientes foram expostos e acessados por terceiros não autorizados, violando o sigilo das informações.

MISSÃO 2: Investigação do Vetor de Ataque (Ameaças e Vulnerabilidades)

A equipe de forense encontrou o seguinte e-mail na caixa de entrada do Gerente Financeiro. Os logs mostram que ele abriu o e-mail e clicou no link minutos antes do travamento geral dos sistemas:

De: suporte-ti-seguranca@etech-update.com.br

Para: financeiro@etech.com.br

Assunto: URGENTE: Atualização de Segurança Necessária

Prezado colaborador,

Detectamos uma tentativa de acesso não autorizado na sua conta corporativa. Clique no link abaixo imediatamente para validar sua senha atual e evitar o bloqueio da sua conta:

<http://login-seguro-etech.net/atualizar-credenciais> Perguntas

Investigativas para a Equipe:

1. Qual o nome técnico desta ameaça (Ex: DoS, Ransomware, Phishing, Engenharia Social)?

O ataque central enviado por e-mail é um Phishing (mais especificamente, Spear Phishing, pois foi direcionado a um alvo estratégico: o Gerente Financeiro). O ataque também se apoia fortemente em técnicas de Engenharia Social, utilizando o senso de urgência e medo para manipular a vítima.

2. Qual vulnerabilidade humana (comportamento) e qual vulnerabilidade técnica do sistema foram exploradas para que esse ataque desse certo?

- **Vulnerabilidade Humana (Comportamental):** Falta de conscientização em segurança da informação (*security awareness*). O gerente agiu sob pressão (senso de urgência artificial criado pelo e-mail) e não verificou a autenticidade do remetente (@etech-update.com.br) nem o link suspeito antes de clicar.

- **Vulnerabilidade Técnica:** Ausência de filtros robustos de segurança de e-mail na empresa (como sistemas de *Anti-phishing*, *Secure Email Gateway - SEG*) e a falta de implementação de políticas de autenticação de e-mail como SPF, DKIM e DMARC, o que permitiu que o e-mail falso chegasse à caixa de entrada do usuário. Além disso, o próprio sistema permitiu o acesso a um domínio externo malicioso (.net) sem bloqueio prévio por um proxy ou firewall de borda.

MISSÃO 3: Auditoria de Infraestrutura (Gerenciamento com SNMP)

Os administradores notaram que as configurações dos roteadores e switches centrais foram alteradas remotamente sem disparar nenhum alarme. Ao verificar o sistema de monitoramento de rede, descobriu-se que a empresa utilizava o protocolo SNMP v2c com a seguinte configuração: Plaintext

Configuração atual detectada nos ativos de rede:

RO Community: public

RW Community: private

Análise Técnica para a Equipe:

1. Expliquem como o uso de community strings no padrão de fábrica facilitou a invasão da rede.

O SNMP v2c transmite suas credenciais (chamadas de *community strings*) em texto puro (sem criptografia) pela rede. Para piorar, a E-Tech utilizava os nomes padrão de fábrica (public para leitura e private para escrita). O atacante realizou uma varredura (scan) na rede e testou essas credenciais padrão. Como a string de escrita (RW - private) estava ativa e previsível, o criminoso ganhou superpoderes sobre os ativos: ele pôde alterar as configurações dos roteadores e switches

remotamente, modificando rotas de rede e interceptando o tráfego sem gerar alertas.

2. Como especialistas, vocês devem exigir a migração imediata para o SNMP v3. Quais são as duas principais melhorias de segurança que essa versão traria para impedir que o atacante "lesse" o tráfego de gerência e alterasse as rotas de rede?

A migração para o SNMP v3 resolve esse cenário crítico através de dois pilares do seu modelo de segurança (USM):

- **Criptografia (Privacidade - *Privacy*):** O SNMP v3 cifra todo o tráfego de gerência utilizando algoritmos robustos (como AES). Isso impede que o atacante consiga "ler" ou farejar (*sniffing*) os dados trafegados na rede.
- **Autenticação Forte:** Diferente das *community strings* em texto plano, o SNMP v3 exige autenticação baseada em usuário e senha com hashes seguros (como SHA-256), garantindo que apenas administradores legítimos possam enviar comandos de alteração de rotas.

MISSÃO 4: Plano de Blindagem e Conformidade (SSL, Criptografia e Privacidade)

Para o relatório final que será entregue à diretoria da E-Tech, debatam e respondam:

1. **Criptografia de Banco de Dados:** Que tipo de criptografia (Simétrica ou Assimétrica) vocês recomendam para proteger os grandes arquivos de backup da empresa de forma rápida e segura? Por quê?

Recomenda-se a Criptografia Simétrica (utilizando o algoritmo AES-256).

- **Por quê?** A criptografia simétrica utiliza a mesma chave para cifrar e decifrar os dados. Ela é extremamente rápida e possui alto desempenho computacional, sendo a escolha ideal para processar grandes volumes de dados, como os arquivos de backup da empresa, garantindo segurança robusta sem travar o desempenho do sistema.
- 2. **Segurança Web:** Descobriu-se que algumas páginas do site não possuíam um certificado SSL válido. Expliquem tecnicamente para os diretores como a ausência do SSL/TLS permite que dados do cliente (como senhas e cartões de crédito) sejam roubados durante a navegação.

Sem o certificado SSL/TLS (o protocolo HTTPS), toda a comunicação entre o navegador do cliente e o servidor da E-Tech ocorre em texto limpo (HTTP). Se um atacante estiver posicionado no meio do caminho da rede (um ataque de *Man-in-the-Middle*), ele pode capturar facilmente os pacotes de dados através de softwares de *sniffing*. Como os dados de senhas e cartões de crédito não estão mascarados por criptografia, o hacker consegue ler as informações exatamente como foram digitadas pelo cliente. O SSL/TLS cria um túnel criptografado que impede essa leitura.

3. Privacidade e Leis: O vazamento dos CPFs dos clientes é um incidente grave. Com base na LGPD (Lei Geral de Proteção de Dados), quais são as possíveis consequências legais e financeiras que a E-Tech pode sofrer por não ter protegido essas informações?

O vazamento de CPFs e e-mails configura uma violação grave de segurança de dados pessoais. Sob a égide da LGPD, a E-Tech pode sofrer:

- **Sanções Financeiras:** Multas administrativas de até 2% do faturamento da empresa, limitadas a R\$ 50 milhões por infração.
- **Sanções Reputacionais e Operacionais:** Obrigação de dar publicidade ao incidente (manchando a marca no mercado), bloqueio ou eliminação dos dados pessoais afetados (o que pode paralisar as operações de marketing e vendas) e processos judiciais de reparação por danos morais e materiais movidos individual ou coletivamente pelos clientes afetados.

Fim do Dossiê - Boa sorte, equipe!